

An Introduction to E-Commerce

with a Focus on Machine Learning, Deep Learning, and Artificial Intelligence

Lecture 13: Security, Privacy, Compliance, and Responsible AI

Dr. Haitham A. El-Ghareeb

Faculty of Computers and Information Sciences
Mansoura University
Egypt

March 23, 2026

Session plan (90 minutes)

- ① Why this chapter matters
- ② Security as a business capability
- ③ Threat modeling for e-commerce platforms
- ④ Identity, authentication, and access control
- ⑤ Payment security and transactional integrity
- ⑥ Managerial implications

Learning objectives

By the end of this lecture, you should be able to:

- explain how security, privacy, compliance, and responsible AI interact in e-commerce platforms;
- identify major risks across payments, customer accounts, APIs, data pipelines, models, and LLM-enabled interfaces;
- apply practical control patterns such as least privilege, data minimization, encryption, audit logging, and human oversight;
- distinguish between technical controls, process controls, and governance controls;
- design a risk assessment and operating model for AI features used in commerce.

Why this chapter matters

- Digital commerce systems sit at the intersection of money, identity, behavioral data, operational processes, and automated decision-making.
- That combination makes them attractive to attackers and highly visible to regulators.
- A mature commerce organization therefore does not treat security as a narrow infrastructure problem, or privacy as a legal afterthought, or responsible AI as a public-relations layer.

Security as a business capability

- customer identities, credentials, sessions, and account recovery channels;
- payment data, refund flows, stored tokens, and settlement operations;
- order data, addresses, invoices, and operational records;
- APIs, integrations, partner connections, and event streams;
- training data, feature tables, prompts, model endpoints, and evaluation artifacts;
- internal administrative tools used by support, finance, merchandising, and operations.

Threat modeling for e-commerce platforms

- **Threat modeling example: intelligent customer support:** a user attempts to retrieve another customer's order details through prompt manipulation;; a malicious knowledge-base document contains adversarial instructions that alter model behavior;

Identity, authentication, and access control

- strong password policies or passwordless flows;
- multi-factor authentication for high-risk actions;
- rate limiting and bot mitigation for login and recovery endpoints;
- device, session, and anomaly-based risk checks;
- secure handling of tokens, cookies, and session expiration.

Payment security and transactional integrity

- minimize the platform's direct exposure to sensitive card data;
- tokenize wherever possible rather than storing primary account details;
- isolate payment services from broader application concerns;
- treat refund and chargeback processes as security-sensitive workflows;
- reconcile payment state carefully across commerce, ERP, and finance systems.

API and integration security

- strong service authentication and secret management;
- explicit authorization scopes for each API consumer;
- request signing or mutual trust mechanisms for sensitive channels;
- replay protection, schema validation, and rate limiting;
- network segmentation and environment isolation;
- monitoring of abnormal patterns in partner or service-to-service traffic.

- **Data minimization in AI systems:** features required for the current decision use case;; features that are merely easy to collect;

Compliance in the commerce environment

- classification of data types and processing activities;
- control mapping to systems, teams, and vendors;
- evidence generation through logs, approvals, and documented processes;
- periodic reviews of access, retention, change management, and incident handling;
- traceability between declared policy and operational reality.

- **High-risk and low-risk AI use cases:** under-governing important systems, which creates real harm;; over-governing trivial systems, which creates bureaucracy without proportional benefit.

Bias, proxies, and unintended discrimination

- a fraud model disproportionately challenging transactions from certain neighborhoods or regions;
- a promotion optimization engine steering premium offers toward already advantaged segments;
- a ranking model reducing visibility for small sellers because historic click-through favors large brands;
- a support triage model assigning slower service to users whose writing style or language differs from the majority training set.

Explainability, contestability, and customer trust

- engineers need diagnostic explanations to debug systems;
- business owners need performance explanations to manage tradeoffs;
- auditors need traceable evidence of control operation;
- customers need plain-language explanations and escalation paths when outcomes affect them materially.

LLM-specific risks and controls

- hallucinated answers about refunds, shipping, warranties, or policy;
- prompt injection through customer messages, seller content, or retrieved documents;
- leakage of personal or confidential data through prompts or logs;
- unsafe action execution when the model is connected to tools;
- over-automation that removes human review from sensitive decisions.
- scoped retrieval and access filtering;

Logging, monitoring, and auditability

- structured logs with consistent identifiers across systems;
- versioning of models, prompts, rules, and datasets;
- records of approvals, overrides, and policy exceptions;
- separation of operational logs from broad user-accessible analytics;
- retention policies that preserve evidence without creating unnecessary data exposure.

Incident response and crisis handling

- detection channels and severity criteria;
- ownership across engineering, security, legal, operations, and communications;
- containment steps for account abuse, data leakage, fraudulent activity, or harmful model behavior;
- evidence preservation requirements;
- decision rules for customer notification, regulator engagement, and vendor escalation;
- post-incident review and control improvement workflows.

Operating model: who owns what

- product owners to define acceptable use and business outcomes;
- engineering teams to implement security and reliability controls;
- data and ML teams to manage datasets, models, evaluation, and monitoring;
- security and privacy specialists to set standards, review risks, and support investigations;
- legal and compliance teams to interpret obligations and approve control approaches;
- frontline operations to handle escalations, appeals, and exception workflows.

A practical risk assessment template

- What decision or assistance function does the system perform?
- Who is affected by the output: customer, seller, employee, or partner?
- What data is used, and which fields are sensitive?
- Could the system materially affect access, price, eligibility, safety, or reputation?
- What failure modes are plausible, and how severe are they?
- What human review, override, or appeal path exists?

Managerial implications

- Executives often ask whether stronger controls slow innovation.
- In reality, the absence of controls slows scaling.
- Teams that do not know which data they can use, which actions models may take, which approvals are required, or how incidents will be handled tend to move either recklessly or not at all.

Hands-on lab: assessing an AI returns assistant

- security: can the assistant expose the wrong order or trigger unauthorized actions?
- privacy: what personal data is retrieved, logged, or retained?
- compliance: are policy promises, consumer rights, and escalation requirements reflected in the workflow?
- responsible AI: could the assistant generate misleading answers, treat some users unfairly, or deny effective recourse?
- a simple architecture diagram;
- a list of assets and trust boundaries;